Umbra Güvenlik Duruşu Raporu

Scope: 127.0.0.1, /tmp/tmpwwalcwug/repo | profile: full | 2026-10-24T16:22:58Z

Grade F Posture score 0/100

CRITICAL	HIGH	MEDIUM	LOW	INFO
5	3	4	1	0

Changes since last scan

First run - this scan established the baseline.

Remediation plan (10 actions)

CRITICAL #1 .env file exposed - Do now, 2 asset(s)

Publicly readable files like this routinely leak source, credentials or internal structure.
How to fix: Block access at the web server, delete the file from the web root, and rotate anything it exposed.

```
# nginx
location ~ /\.(git|svn|env|DS_Store) { deny all; return 404; }
# apache
<FilesMatch "^\.(git|svn|env|DS_Store)">
  Require all denied
</FilesMatch>
# remove the file from the web root and ROTATE any credentials it contained
```

Affected: 127.0.0.1:45745 (http://127.0.0.1:45745/.env returned HTTP 200); 127.0.0.1:46287 (https://127.0.0.1:46287/.env returned HTTP 200)

CRITICAL #2 Git repository exposed - Do now, 2 asset(s)

Publicly readable files like this routinely leak source, credentials or internal structure.
How to fix: Block access at the web server, delete the file from the web root, and rotate anything it exposed.

```
# nginx
location ~ /\.(git|svn|env|DS_Store) { deny all; return 404; }
# apache
<FilesMatch "^\.(git|svn|env|DS_Store)">
  Require all denied
</FilesMatch>
# remove the file from the web root and ROTATE any credentials it contained
```

Affected: 127.0.0.1:45745 (http://127.0.0.1:45745/.git/HEAD returned HTTP 200); 127.0.0.1:46287 (https://127.0.0.1:46287/.git/HEAD returned HTTP 200)

CRITICAL #3 AWS access key ID in source - Do now, 1 asset(s)

Credentials in code end up in git history, CI logs, backups and screenshots.
How to fix: Revoke/rotate the credential first, then move it to a secret manager or environment variable and add a pre-commit scanner.

```
# 1. rotate the secret at the provider
# 2. load it from the environment instead
import os
TOKEN = os.environ['SERVICE_TOKEN']
# 3. block future leaks
pip install pre-commit  # then add gitleaks hook to .pre-commit-config.yaml
```

Affected: repo/app.py (AKIA...**** (line 1))

HIGH #4 Certificate fails validation - This week, 1 asset(s)

Browsers and API clients will reject this certificate, or users learn to click through warnings.
How to fix: Serve a certificate from a trusted CA that covers this hostname, including the full intermediate chain.

```
sudo certbot renew --dry-run && sudo certbot renew
# or request a new cert
sudo certbot --nginx -d 127.0.0.1
```

Affected: 127.0.0.1:46287 (self-signed certificate)

HIGH #5 Missing security headers - This week, 1 asset(s)

These response headers harden browsers against XSS, clickjacking, MIME sniffing and downgrade attacks.
How to fix: Add the headers at your reverse proxy / web server (snippets below), then re-scan. Test CSP in report-only mode first.

```
# nginx (server or location block)
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
add_header Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-
src 'none'; base-uri 'self'" always;
add_header X-Content-Type-Options "nosniff" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "camera=(), microphone=(), geolocation=()" always;
add_header X-Frame-Options "SAMEORIGIN" always;

# apache (mod_headers)
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"
Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'"
Header always set X-Content-Type-Options "nosniff"
Header always set Referrer-Policy "strict-origin-when-cross-origin"
Header always set Permissions-Policy "camera=(), microphone=(), geolocation=()"
Header always set X-Frame-Options "SAMEORIGIN"
```

Affected: 127.0.0.1:46287 (strict-transport-security, content-security-policy, x-content-type-opt)

HIGH #6 TLS certificate expires within 7 days - This week, 1 asset(s)

How to fix: Renew now and set up automatic renewal with monitoring.

```
sudo certbot renew --dry-run && sudo certbot renew
# or request a new cert
sudo certbot --nginx -d 127.0.0.1
```

Affected: 127.0.0.1:46287 (2 day(s) left)

MEDIUM #7 Unexpected open port 39365/tcp (unknown) - This sprint, 2 asset(s)

127.0.0.1:39365 is reachable but not in policy.allowed_ports. Exposed management and database services are a common breach path.
How to fix: Block the port at the firewall/security group, bind the service to localhost or a private network, or — if it is intentional — accept it with `umbra baseline accept`.

```
# ufw
sudo ufw deny 39365/tcp
# iptables
sudo iptables -A INPUT -p tcp --dport 39365 -j DROP
# or allow only your admin IP
sudo ufw allow from <ADMIN_IP> to any port 39365 proto tcp
```

Affected: port:127.0.0.1:39365 (hosts: 127.0.0.1); port:127.0.0.1:45745 (hosts: 127.0.0.1)

MEDIUM #8 HTTP does not redirect to HTTPS - This sprint, 1 asset(s)

How to fix: Redirect all plain-HTTP traffic to HTTPS.

```
# nginx
server { listen 80; server_name _; return 301 https://$host$request_uri; }
```

Affected: 127.0.0.1:45745 (HTTP 200)

MEDIUM #9 Cookie missing security flags - This sprint, 1 asset(s)

How to fix: Set Secure, HttpOnly and SameSite on session cookies.

```
Set-Cookie: session=...; Path=/; Secure; HttpOnly; SameSite=Lax
```

Affected: 127.0.0.1:46287 (sid: missing Secure, HttpOnly, SameSite)

LOW #10 Server discloses software version - Backlog, 1 asset(s)

Version banners help attackers pick known exploits.
How to fix: Hide version information.

```
# nginx
server_tokens off;
# apache
ServerTokens Prod
ServerSignature Off
# php.ini
expose_php = Off
```

Affected: 127.0.0.1:46287 (server: BaseHTTP/0.6 Python/3.12.3, nginx/1.18.0)

Asset inventory (6)

Kind	Value	Source
certificate	127.0.0.1:46287	tls
host	127.0.0.1	scope
port	127.0.0.1:39365	portscan
port	127.0.0.1:45745	portscan
port	127.0.0.1:46287	portscan
repo	/tmp/tmpwwalcwug/repo	scope